

CSE 331: Computer Security Fundamentals

Spring 2026

Network Security:
BGP

Amir Rahmati
Xinrui Yu



Stony Brook Institute
at Anhui University

安徽大学纽约石溪学院

IP Addressing and Forwarding

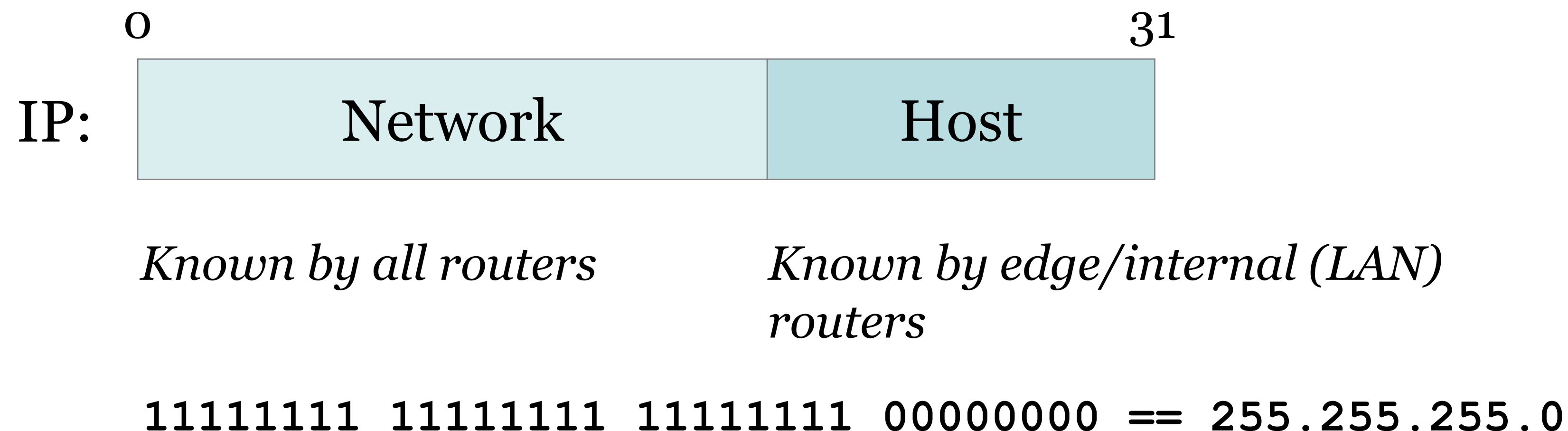
Packets are routed based on their destination IP address

Router's task: for every possible IP address, forward packet to the next hop

Table lookup for each packet in a routing table

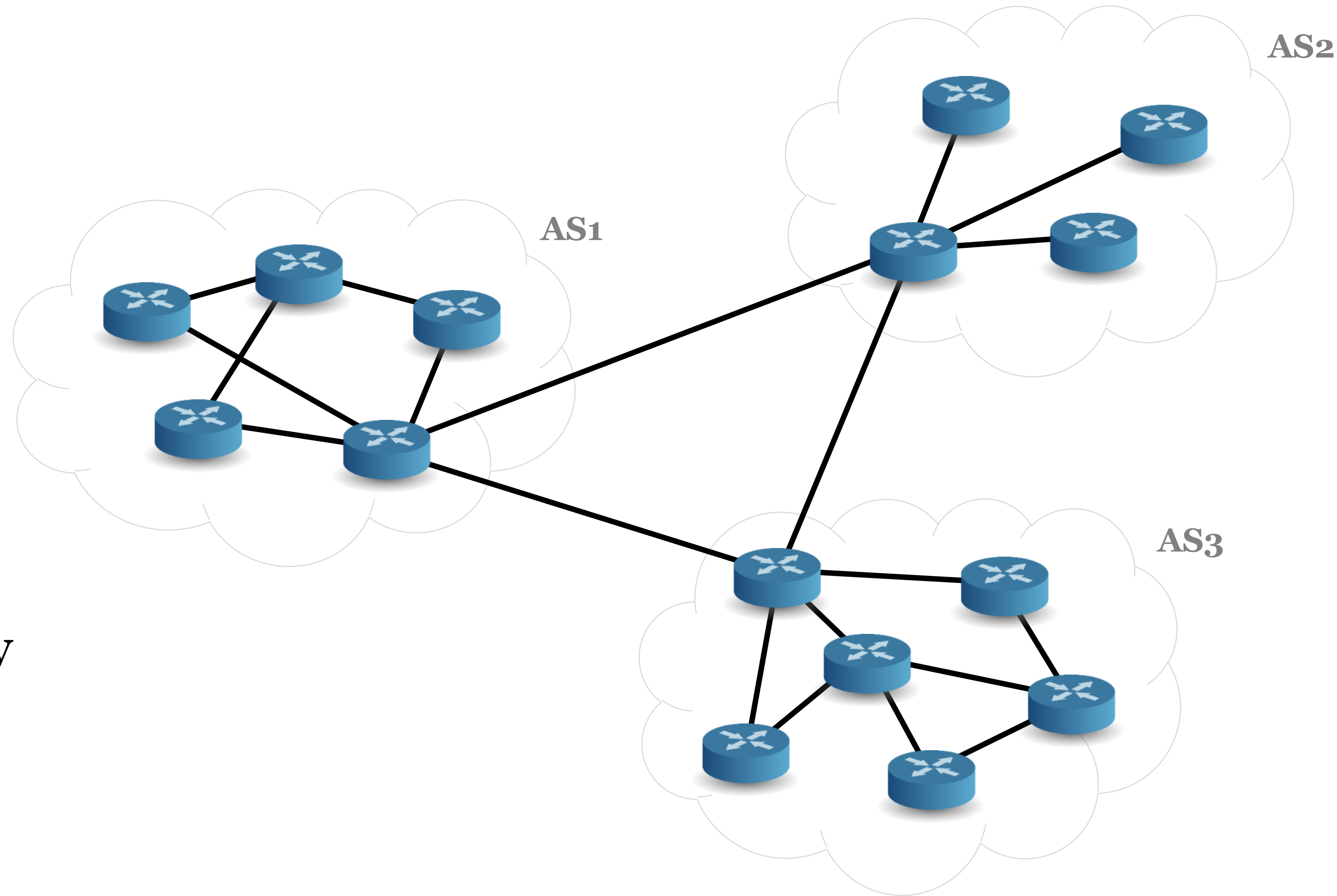
For 32-bit addresses, 2^{32} possibilities! - Previously impractical

Solution: hierarchical address scheme

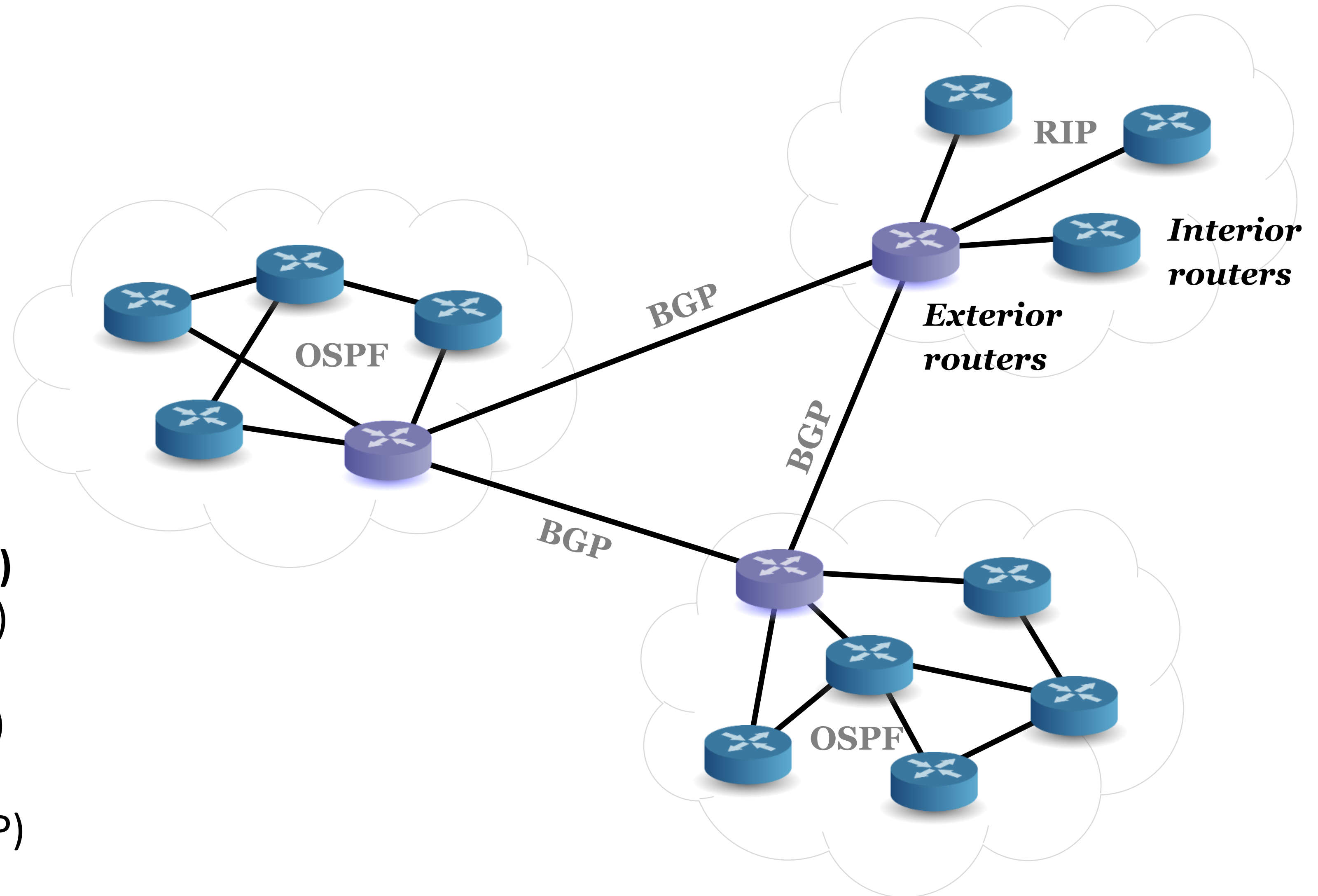


Autonomous Systems

- Collection of IP prefixes
- Single administrative entity
- Common routing policy
- Defined as 16 bit integer
- Registered by a regional Internet registry (RIR)



Internet Routing



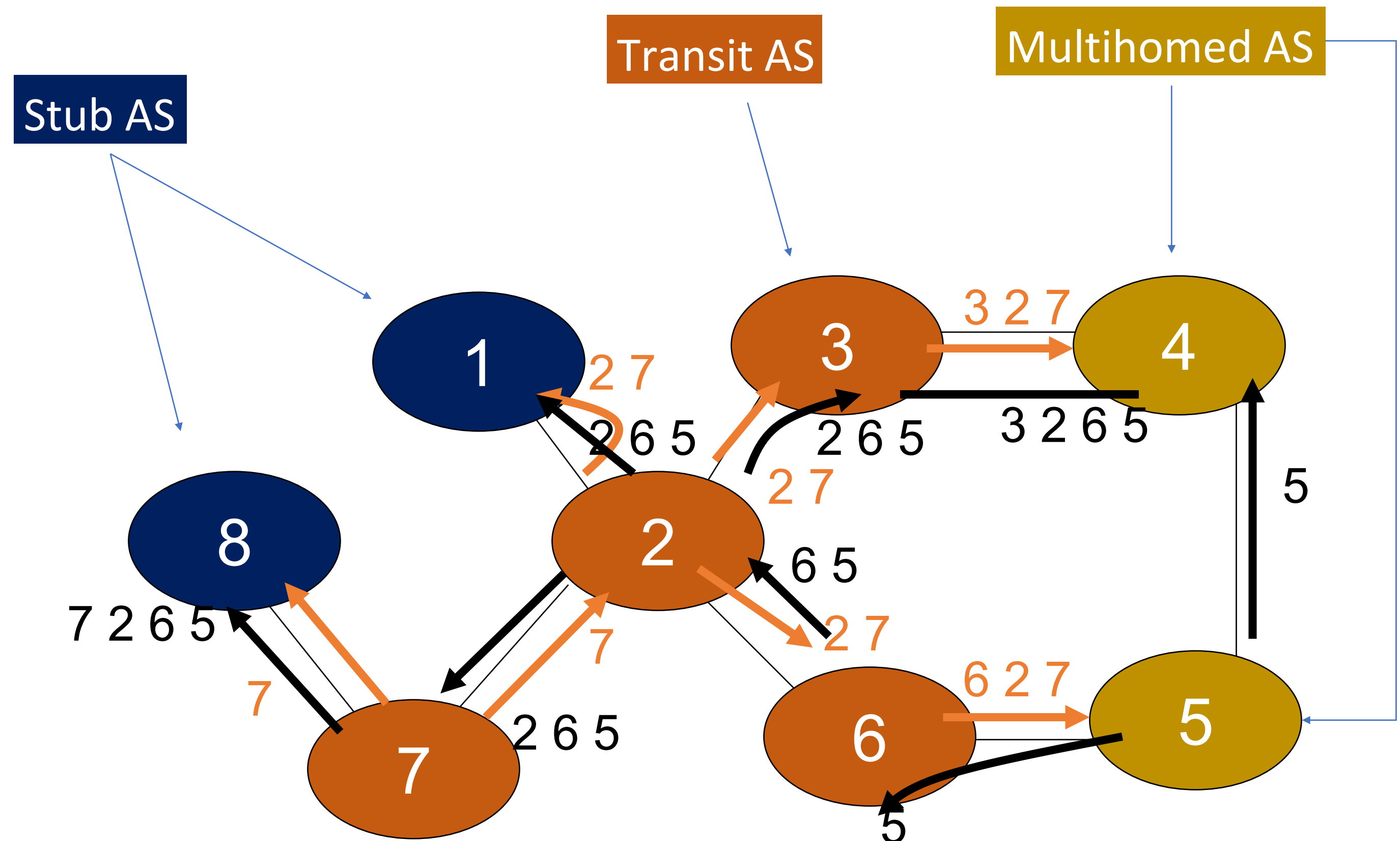
Exterior Gateway Protocol (EGP)
Border Gateway Protocol (BGP)

Interior Gateway protocol (IGP)
Open shortest-path first (OSPF)
Routing Information Protocol (RIP)

BGP example

BGP Goals

- Obtain subnet reachability information from neighboring ASs
- Propagate the reachability information to all internal routers
- Determine “good” routes to subnets based on the reachability information and AS policy.
- Policy is decided based on economic, security, political, ... considerations



Root Causes of BGP Security Issues

- No authentication of path announcements
 - Neighbor adjacencies can be “secured” using MD5 digests
- BGP messages are sent over TCP connections
 - All the usual problems: eavesdropping, content manipulation, ...
- Misconfigurations are easy
 - BGP is a complex protocol, with complex interactions

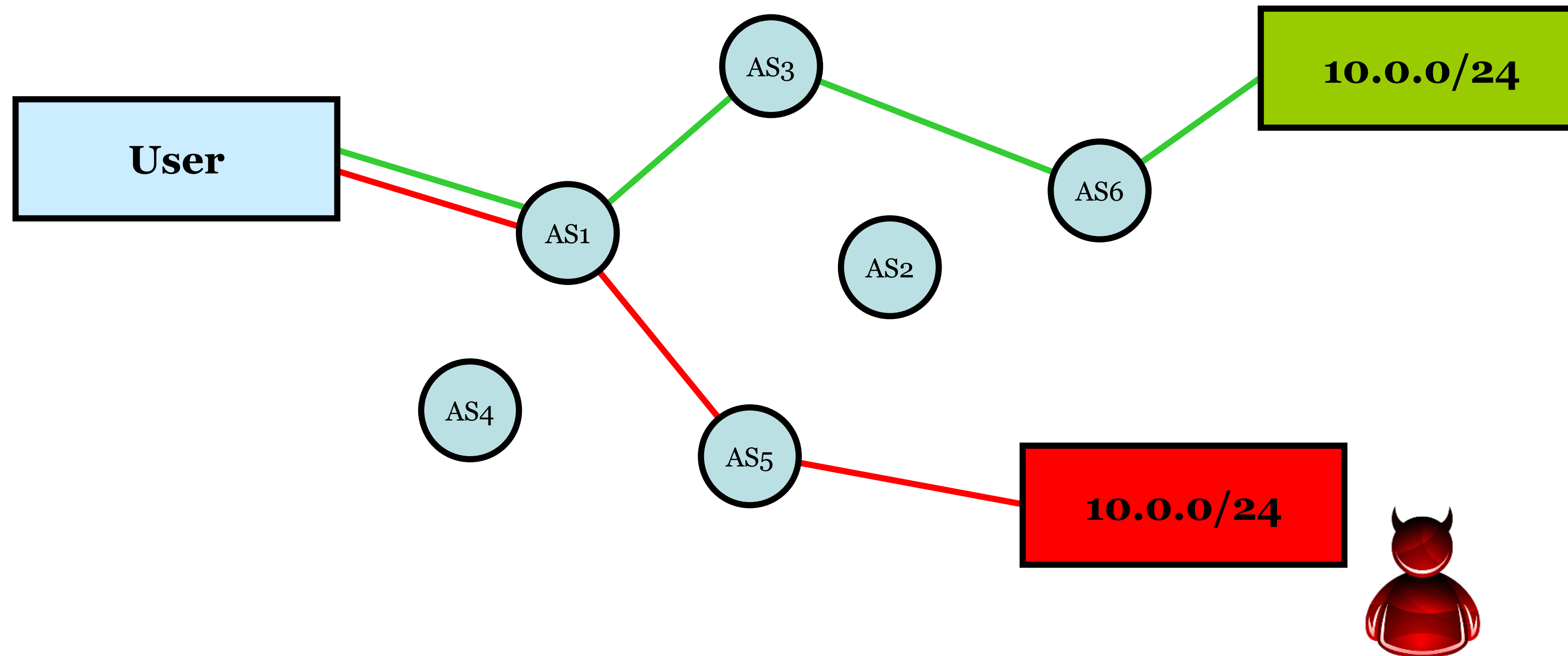
Attackers can lie to other routers

Routing Attacks

- **Blackholing:** False route advertisements to attract and drop traffic
- **Redirection:** Force traffic to take a different path, either for interception (MitM) or to cause congestion
- **Instability:** Frequent advertisements and withdrawals and/or increased BGP traffic to cause connectivity outages
- **How?**
 - Configuration mistakes
 - Insider attacks
 - Compromised routers
 - BGP traffic manipulation

Prefix Hijacking

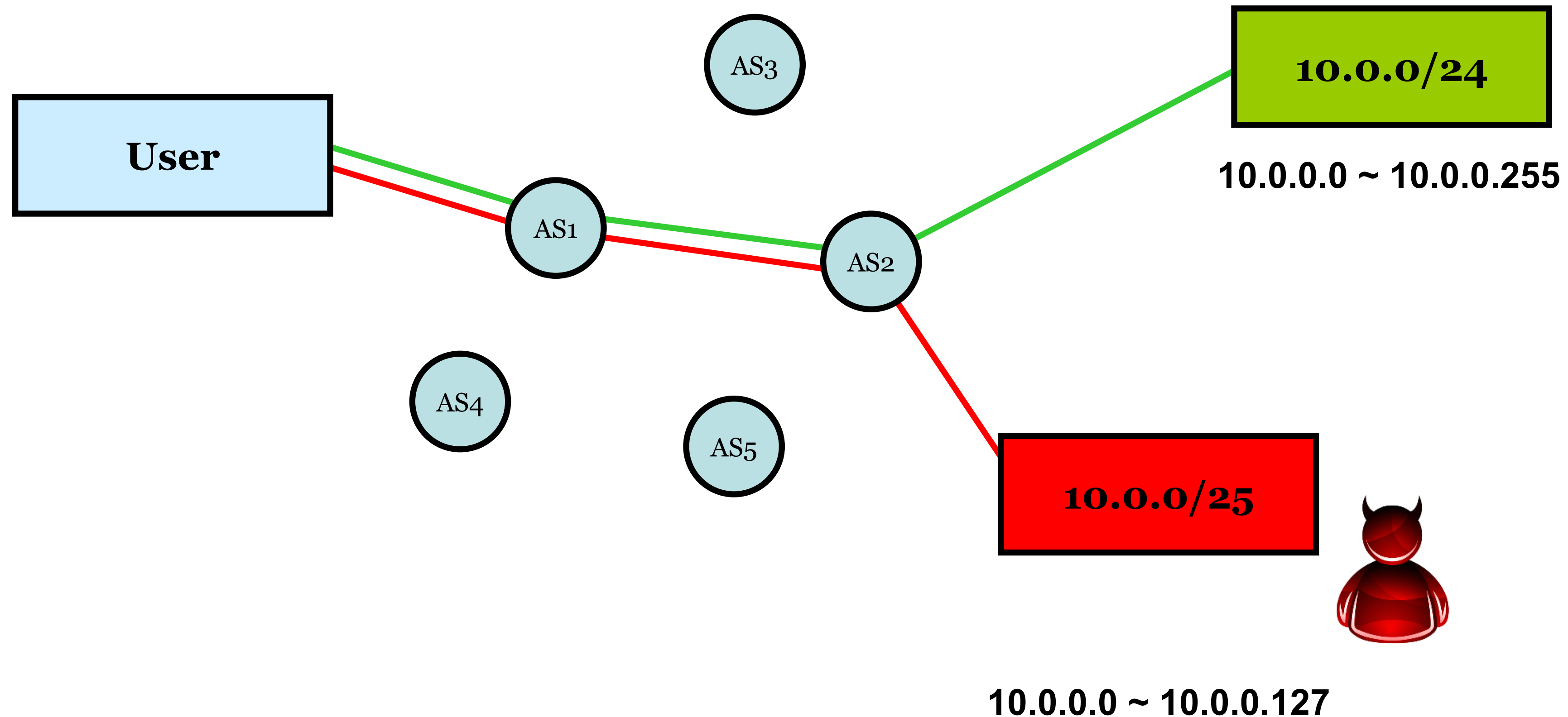
Announce someone else's prefix
Victim prefers the *shortest* path



Prefix Hijacking

Announce a more specific prefix than someone else

Victim prefers the *more specific* path





SUBSCRIBE **GIVE A GIFT** **RENEW** **INTERNATIONAL ORDERS**

FOLLOW WIRED



BY RYAN SINGEL 02.25.08 | 10:37 AM | PERMALINK



Free download: [Best Practices For Ensuring Cloud Compliance](#).

Threat Protection Tool

C++ Static Analysis

AVG® Business Research

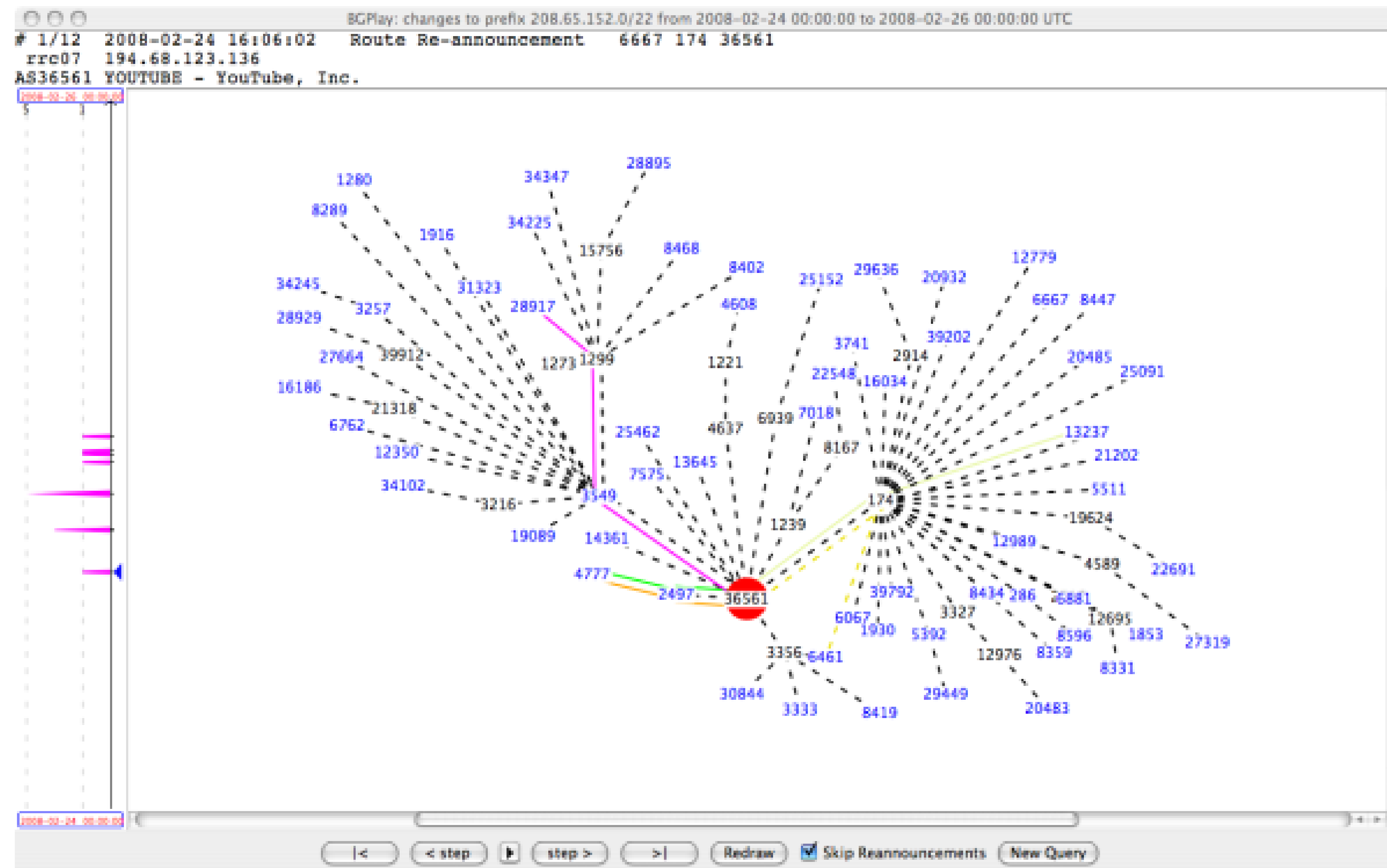
Security White Papers

Cisco® ACI Virtualization

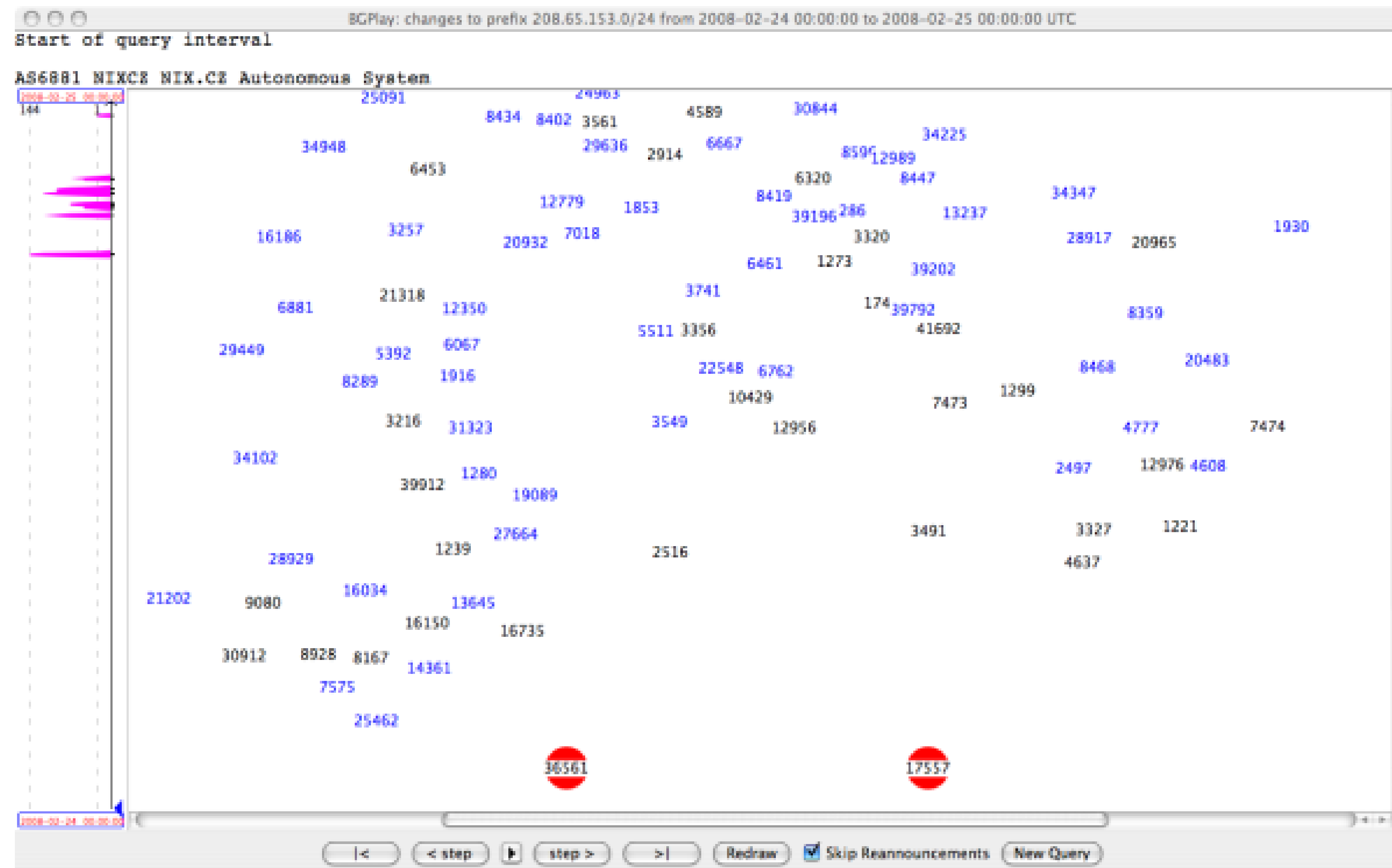
IoT Security Explained

Immediate Risk Assessment

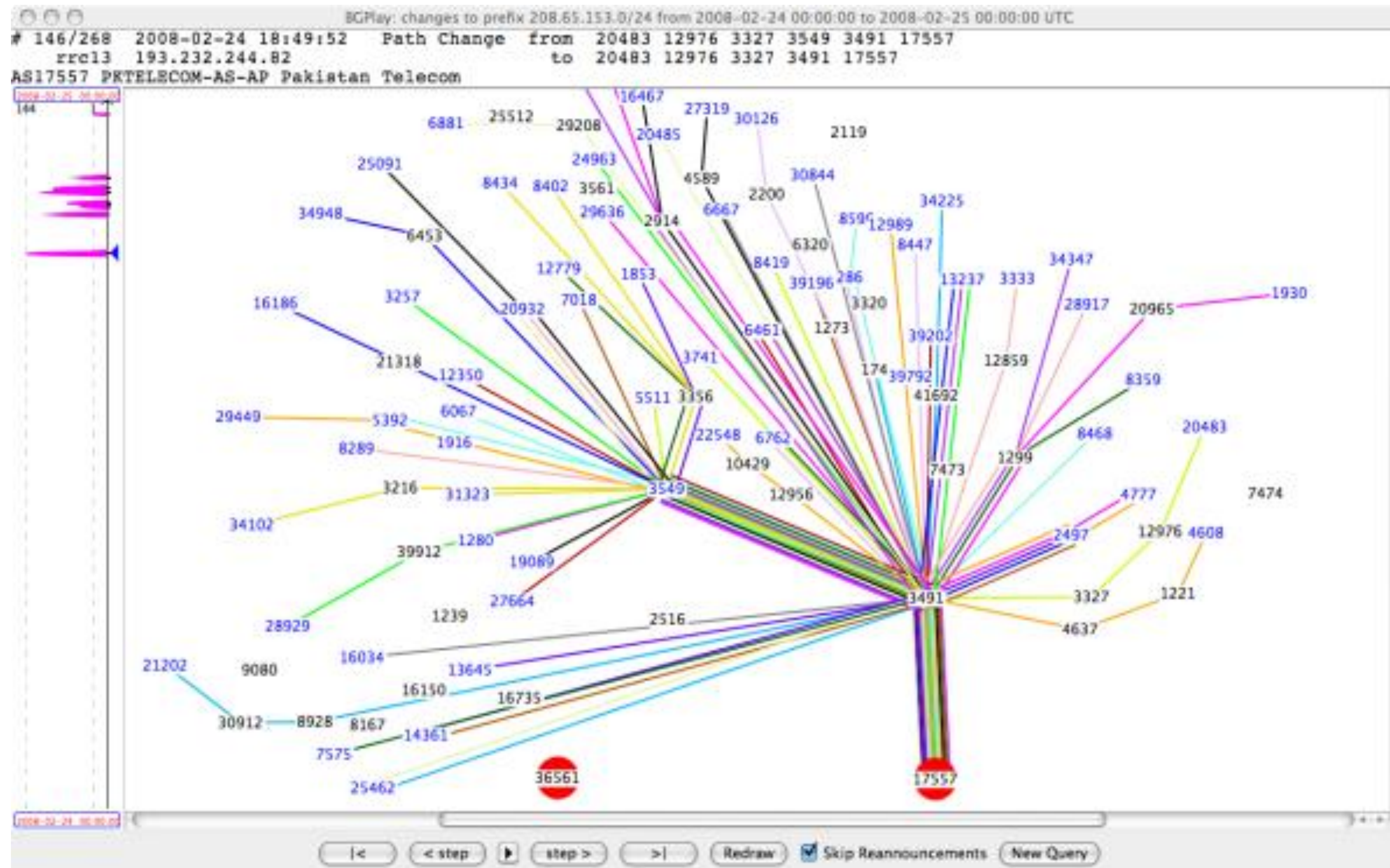
AS36561 (YouTube) announces 208.65.152.0/22



The prefix 208.65.153.0/24 is not announced on the Internet before the event



AS17557 (Pakistan Telecom) announces 208.65.153.0/24

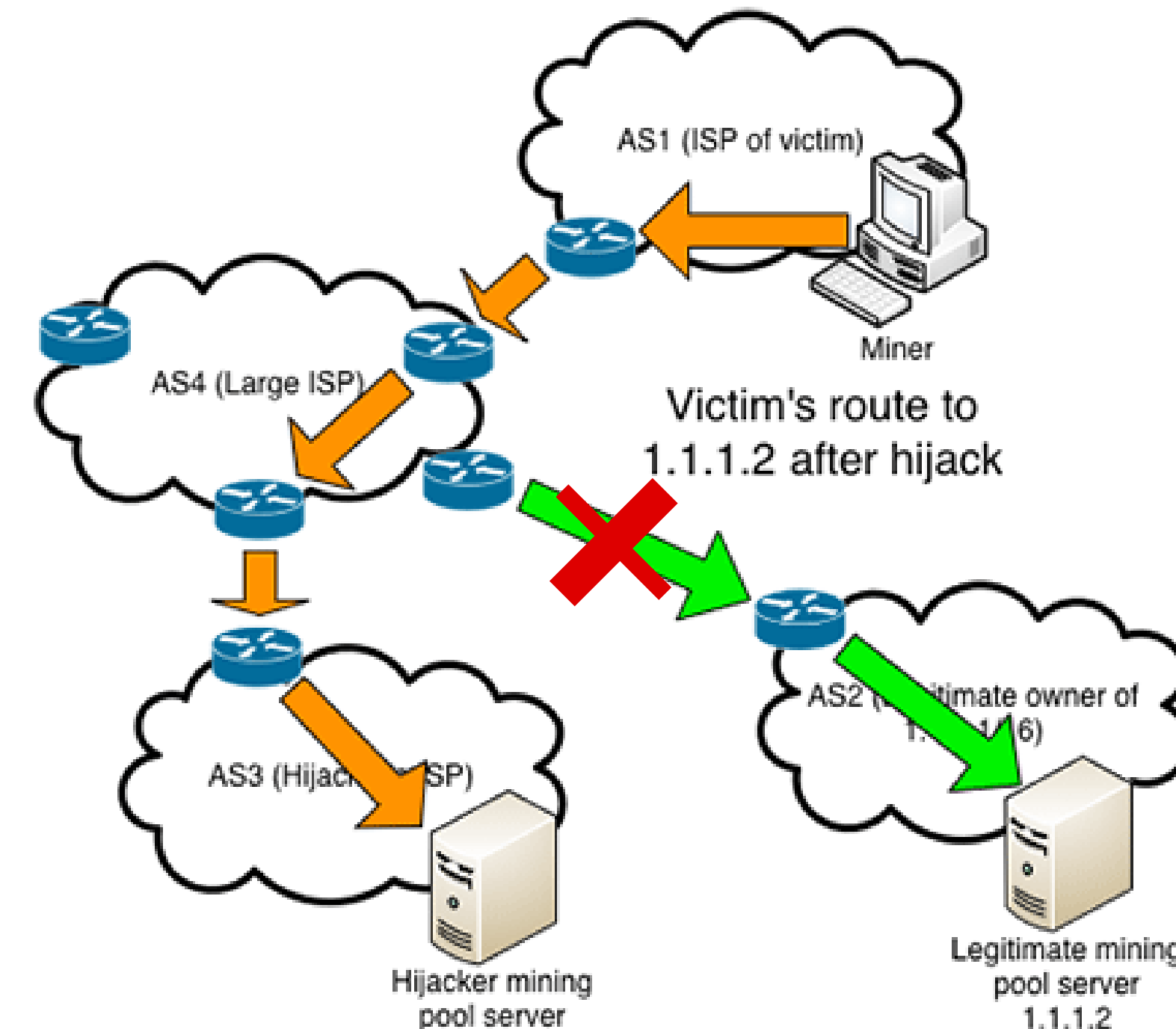


Notable Incident

February 2014: hijacking of 51 networks (incl. Amazon, Digital Ocean, OVH)

Miner connections were redirected to an attacker-controlled mining pool

Attacker collected the miners' profit (est. \$83,000 in 4 months)



Mitigating BGP Threats

Neighbor authentication

Only authorized peers can establish a given BGP neighbor relationship

TTL check

Most external peering sessions established between adjacent routers

Good idea: set TTL=1 ☹ an attacker X hops away can still set TTL=1+X

Better idea: set TTL=255 and accept only packets with TTL=255 ☹ an attacker further away cannot spoof such a packet

BGP prefix restrictions and filtering

Accept only a certain number of prefixes, ignore unwanted/illegal prefixes, limit the number of accepted AS path segments, ...

Access Lists (ACL) to explicitly permit only authorized BGP traffic

According to existing security policies and configurations

Securing BGP

Resource Public Key Infrastructure (RPKI)

Certified mapping from ASes to public keys and IP prefixes

BGPSec

Allow recipients to validate the AS path included in update messages

Resource Public Key Infrastructure (RPKI)

- The top level, Regional Internet Registries (RIRs) act as root Certificate Authorities. They issue certificates to organizations that own IP address blocks and AS numbers.
- Certificate for an organization contains the list of IP prefixes it owns and is authorized to advertise.
- Focuses on **origin validation** – prevents prefix hijacking

BGPSec

- Each Autonomous System (AS) digitally signs its portion of the AS path when forwarding a route to a neighbor. – prevents path hijacking
- BGPSec is streamlined, focusing mainly on AS path validation and working closely with RPKI for origin validation.
- Leverages RPKI for origin validation and focuses on securing the path separately.

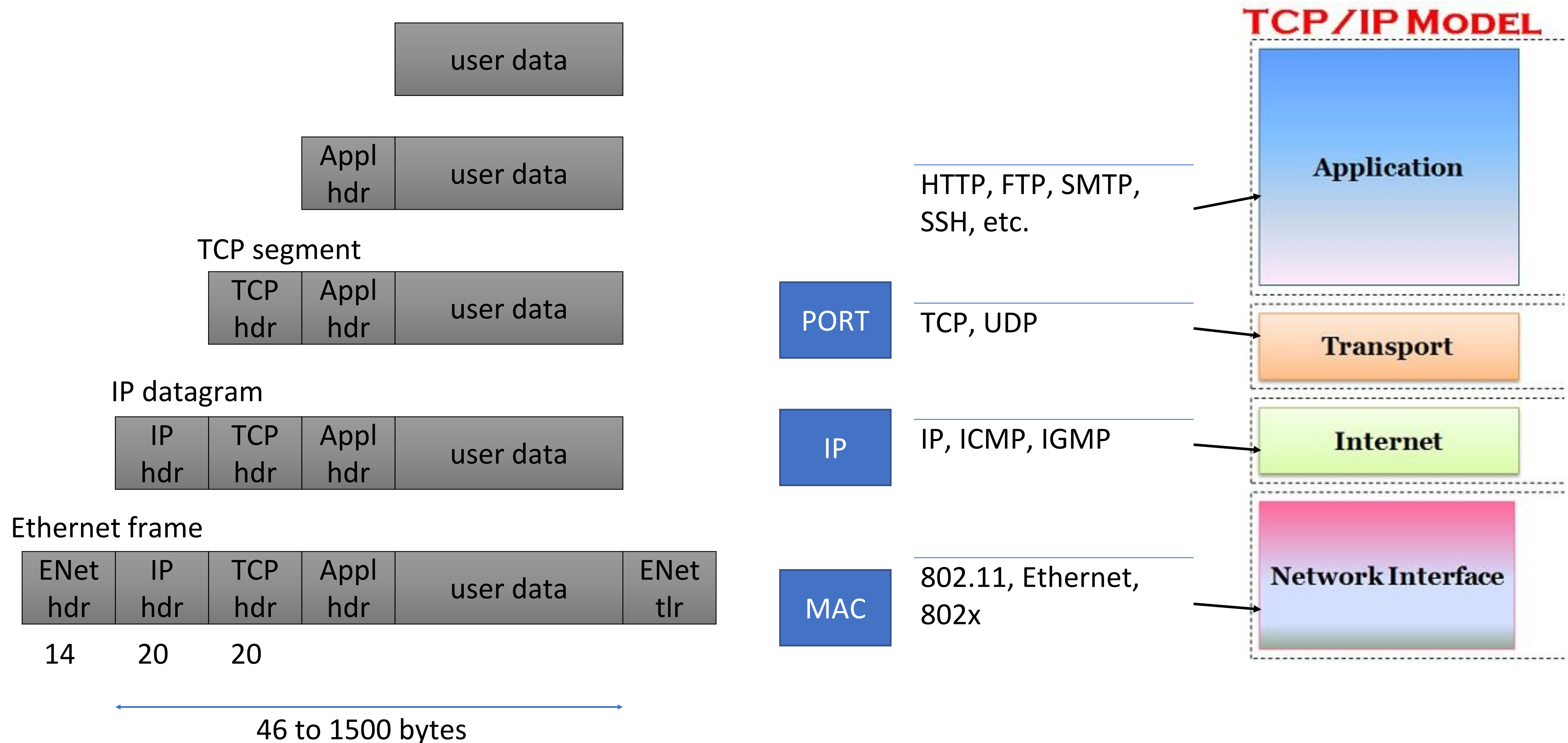
Many deployment challenges

- No complete, accurate registry of prefix ownership
- Need for a public-key infrastructure
- Cannot react rapidly to changes in connectivity
- Cost of cryptographic operations
- Incremental deployment not always possible

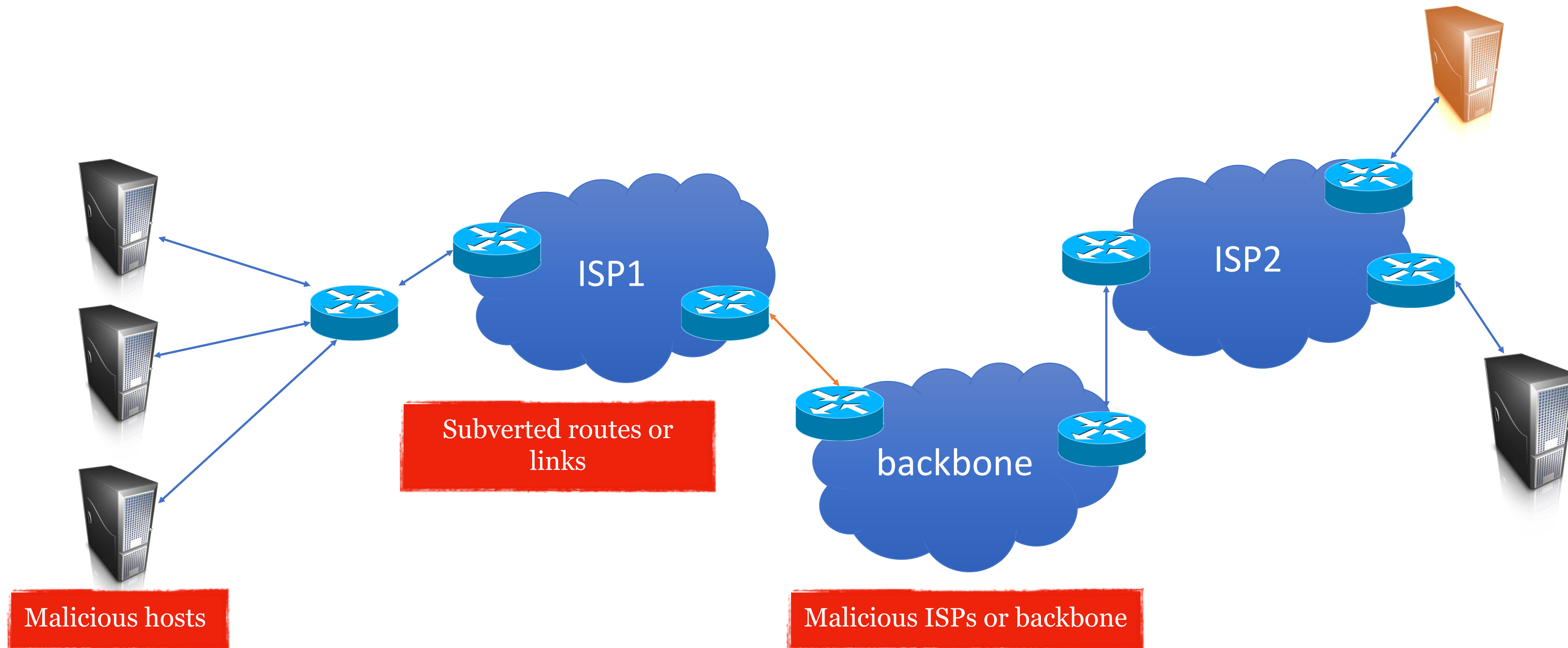
Internet Security

- Recurring themes:
 - Built without any authenticity mechanisms in mind
 - Functionality mechanisms (sequence #'s) become implicit security mechanisms
- New attempts at (somewhat) backwards-compatible security mechanisms
 - IP -> IPsec
 - DNS -> DNSsec
 - BGP -> BGPsec

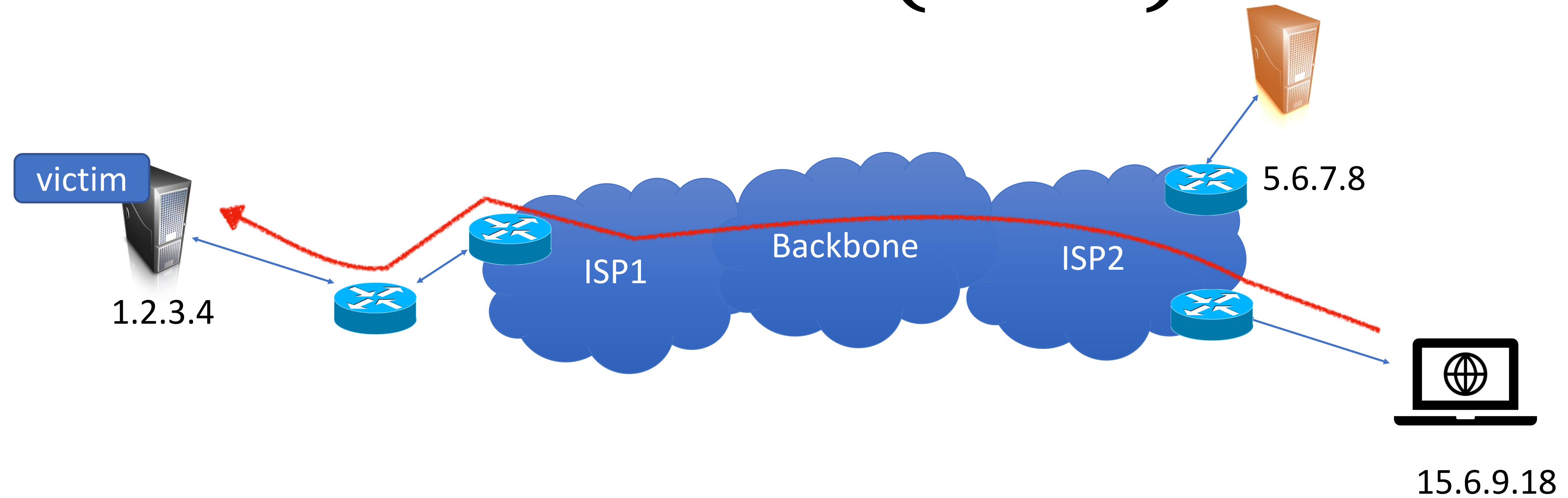
Recap: Internet Protocol Stack



Recap: Network threat model



Denial of Service (DoS) attacks

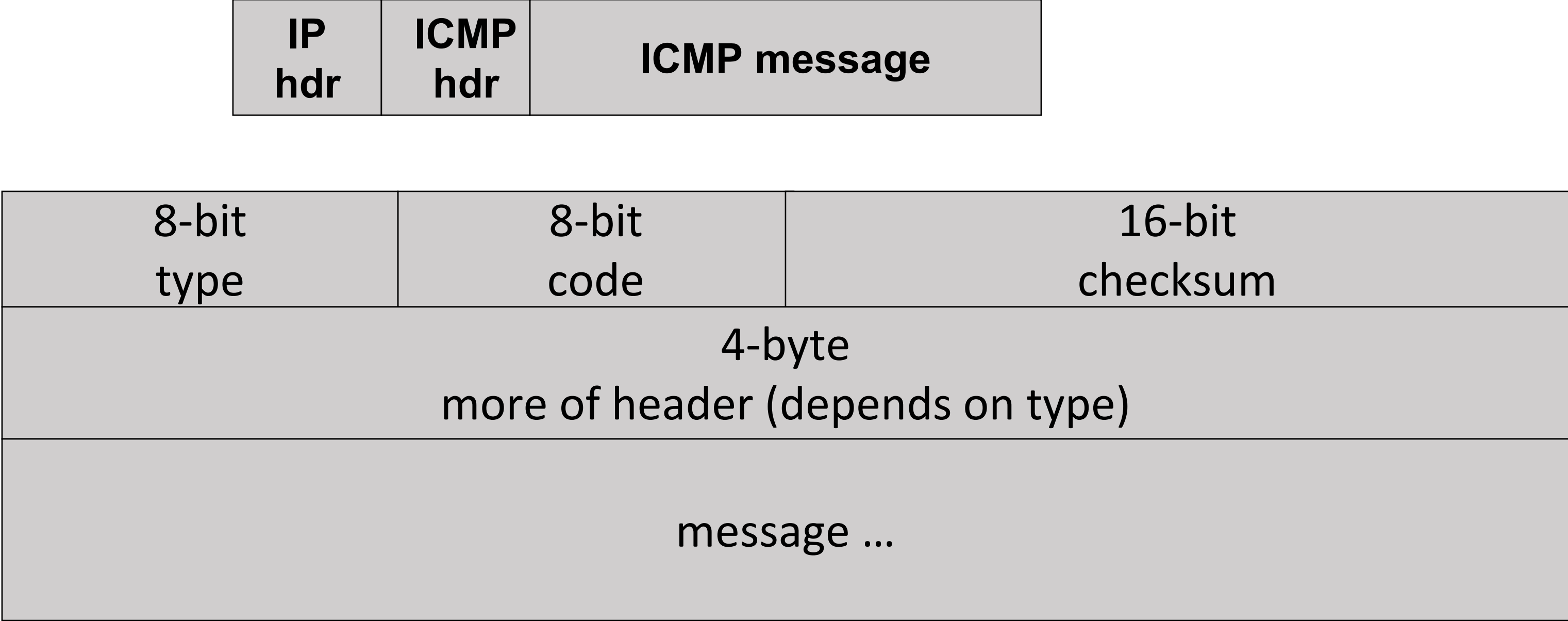


Goal: prevent legitimate users from accessing victim (1.2.3.4)

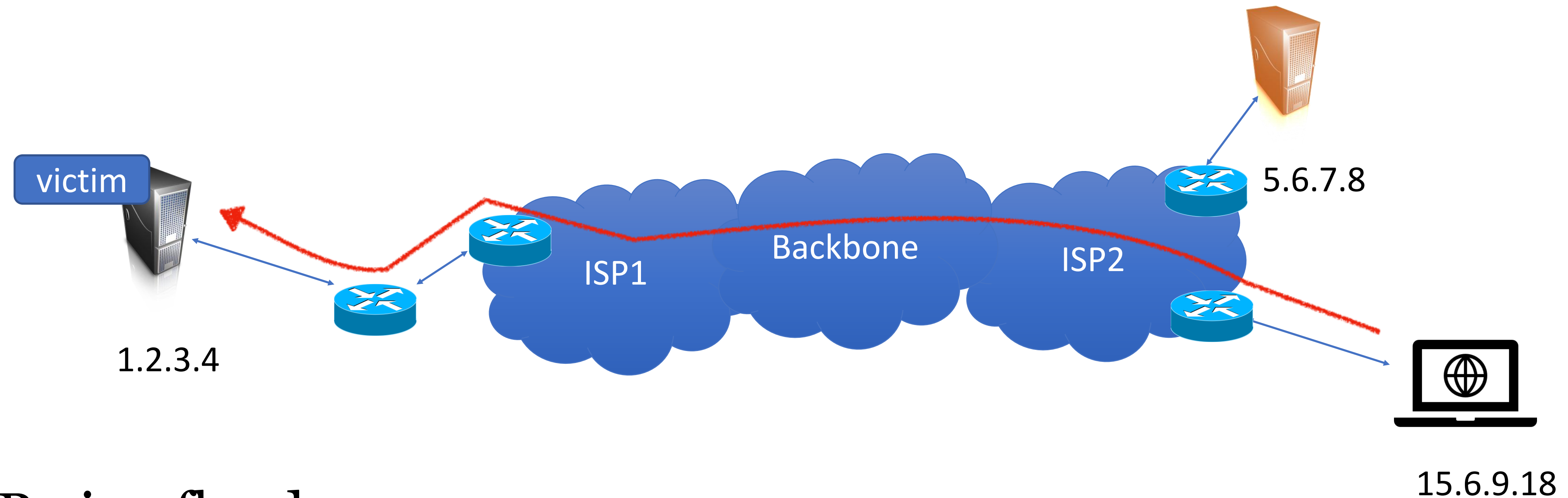
DoS

- Overwhelm the victim with malicious traffic
 - E.g., ICMP Flood, SYN flood
- Many types
 - **Application layer DoS**
 - Locking all user accounts in a system (by repeated password guesses)
 - **Distributed DoS**
 - Get a pool of (compromised) machines/devices to send malicious traffic
 - SYN floods
 - **Reflected DoS**
 - Send spoofed IP packets to benign servers who responds with large amount data

ICMP (Internet Control Message Protocol)



ICMP Flood

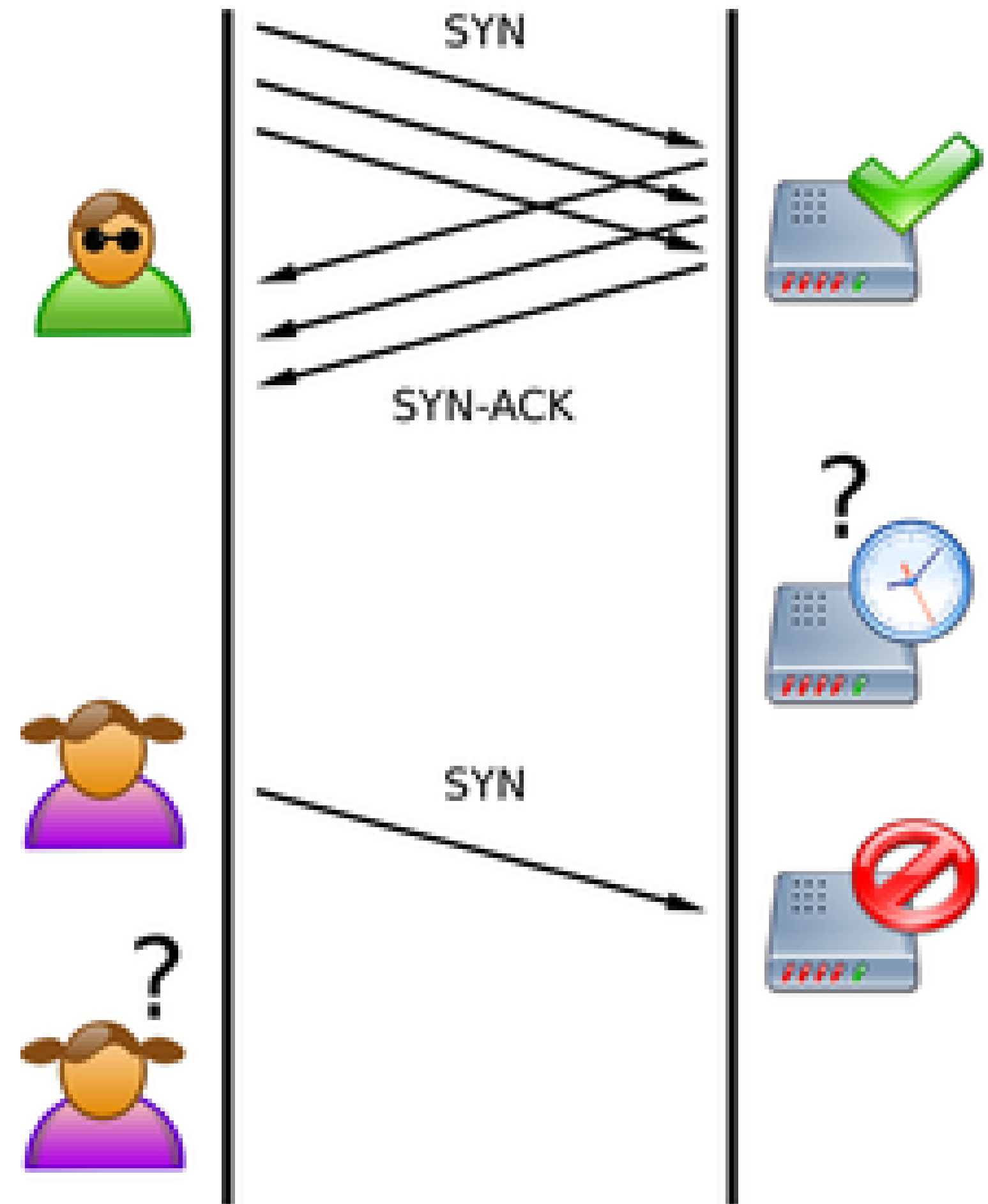


ICMP ping flood

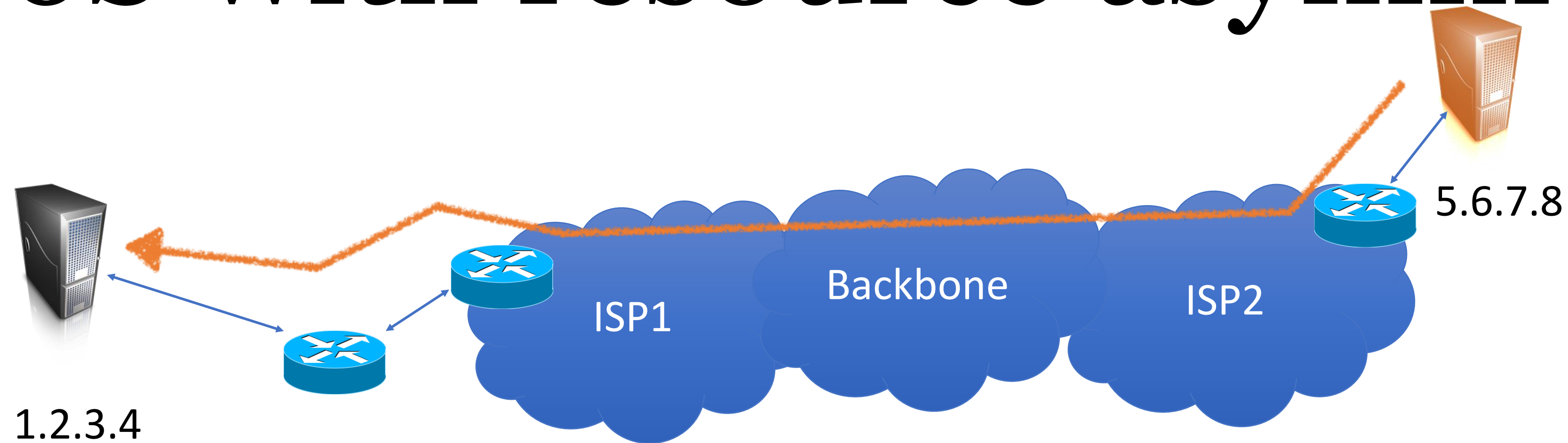
- Attacker sends ICMP pings as fast as possible to victim
- When will this work as a DoS? **Attacker resources > victim's**
- How can this be prevented? **Ingress filtering near victim**

TCP SYN Flood

- Send a bunch of SYN packet to a router/server
 - Never respond with an ACK
 - Half-open TCP connections hold resources in the server
 - Legitimate users cannot access the server



DoS with resource asymmetry



Attacker uses few resources to cause victim to consume lots of resources

- **DNS amplification attack**

- Send DNS request w/ spoofed target IP (~64-byte request)
- DNS replies sent to target (~512-byte response)

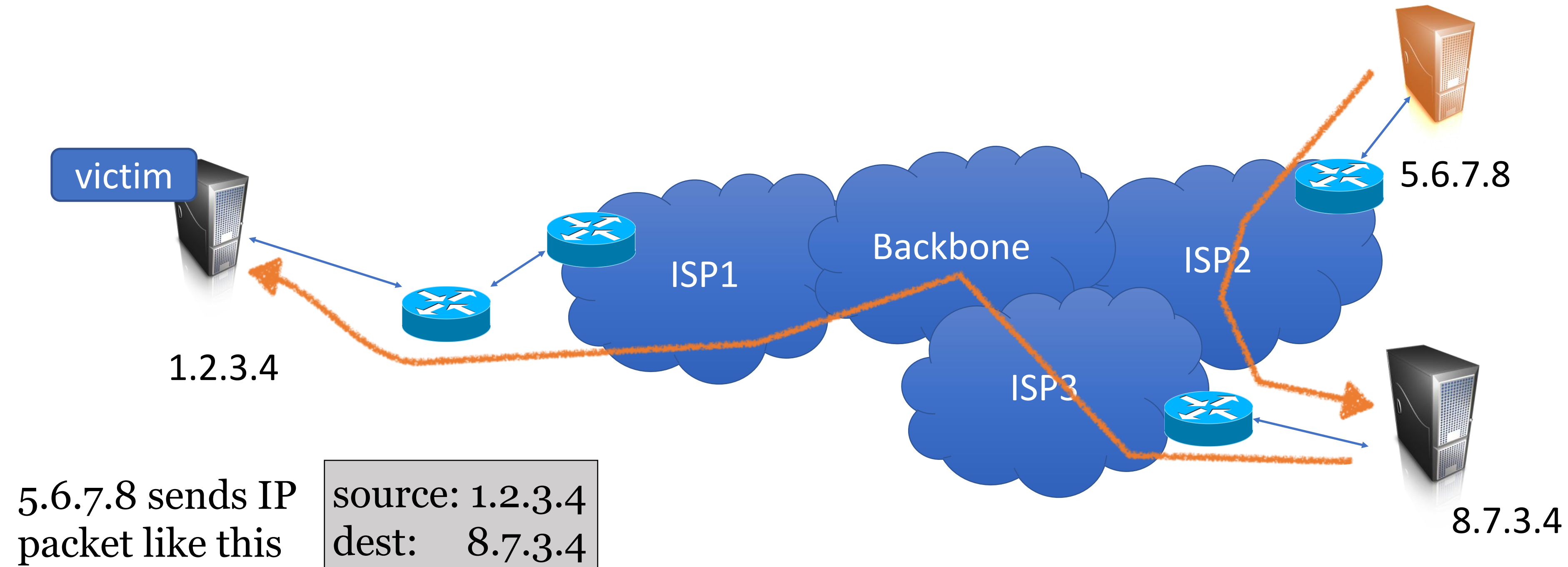
- **Smurf Attack**

- Broadcast ICMP ping on a router with spoofed victim's IP address
- (not allowed with newer router)

- **Ping of death**

- A single packet that causes crash on remote system
- Early on: ping packet with size > 65,535

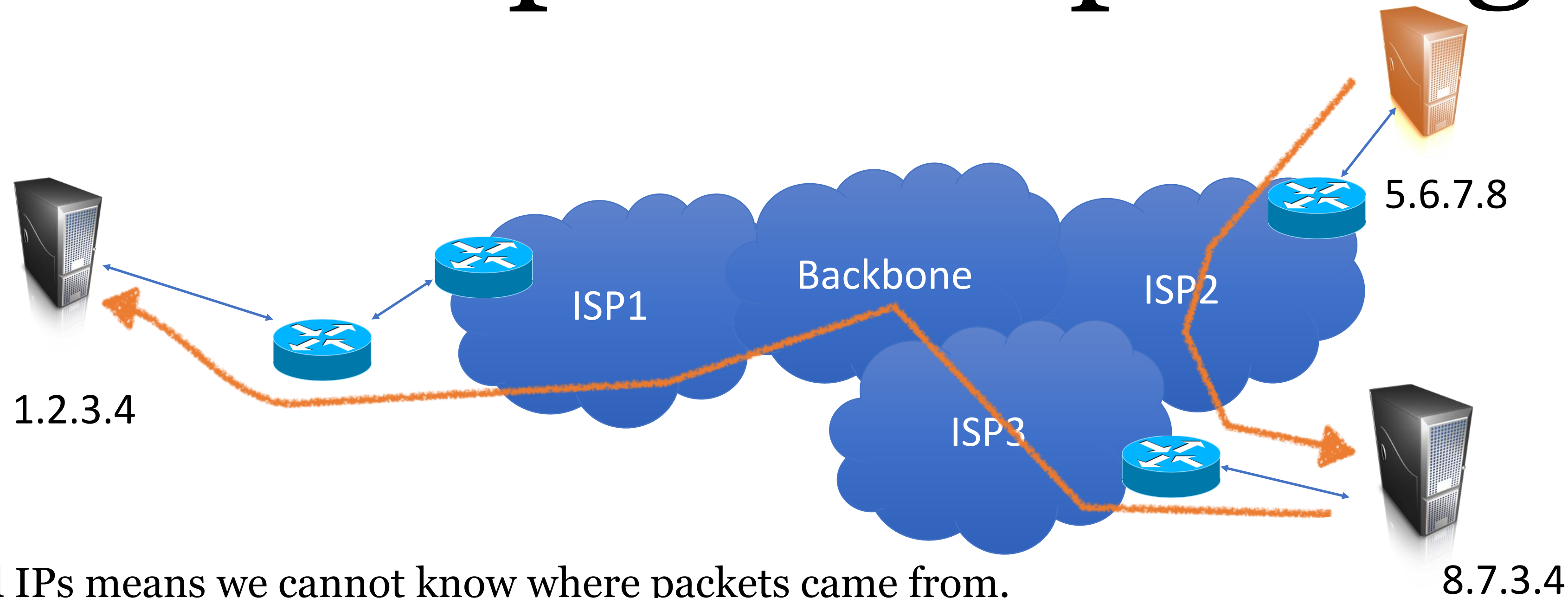
Reflected DoS attacks



Attacker sends packets with spoofed source address

Filter based on source may be incorrect

How to prevent spoofing?

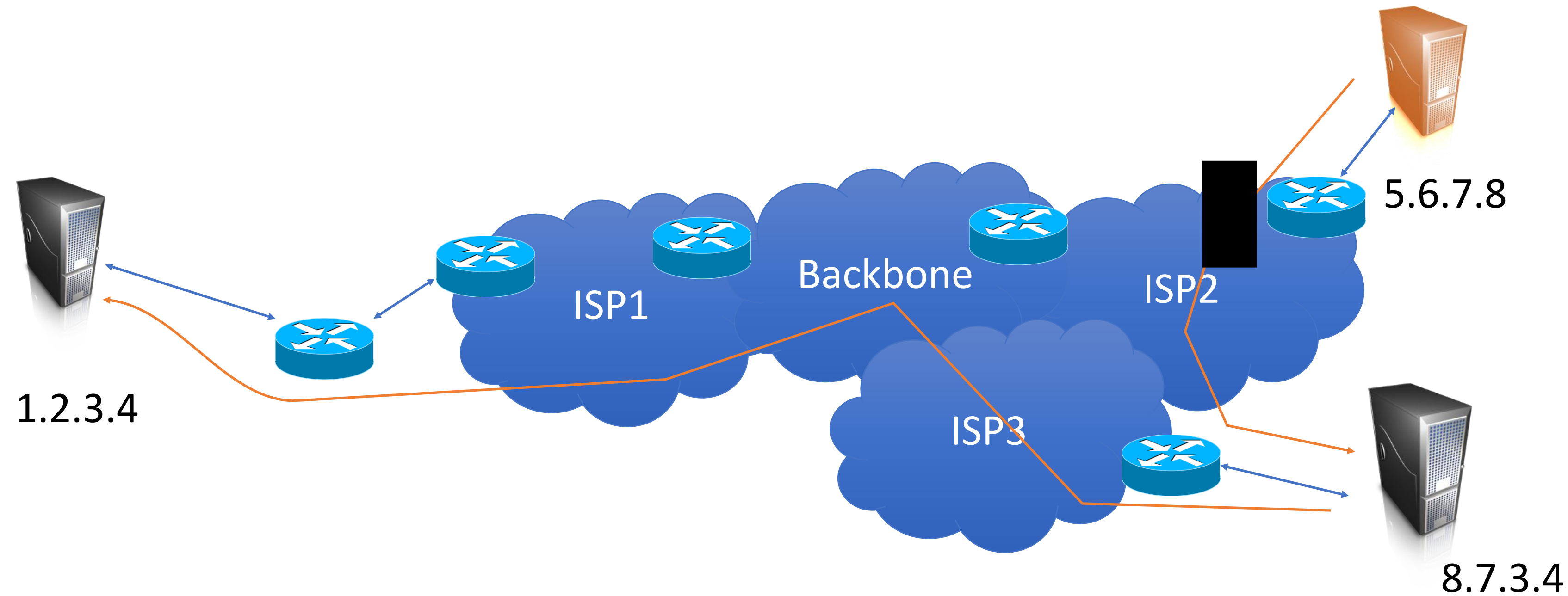


Spoofed IPs means we cannot know where packets came from.

Solution:

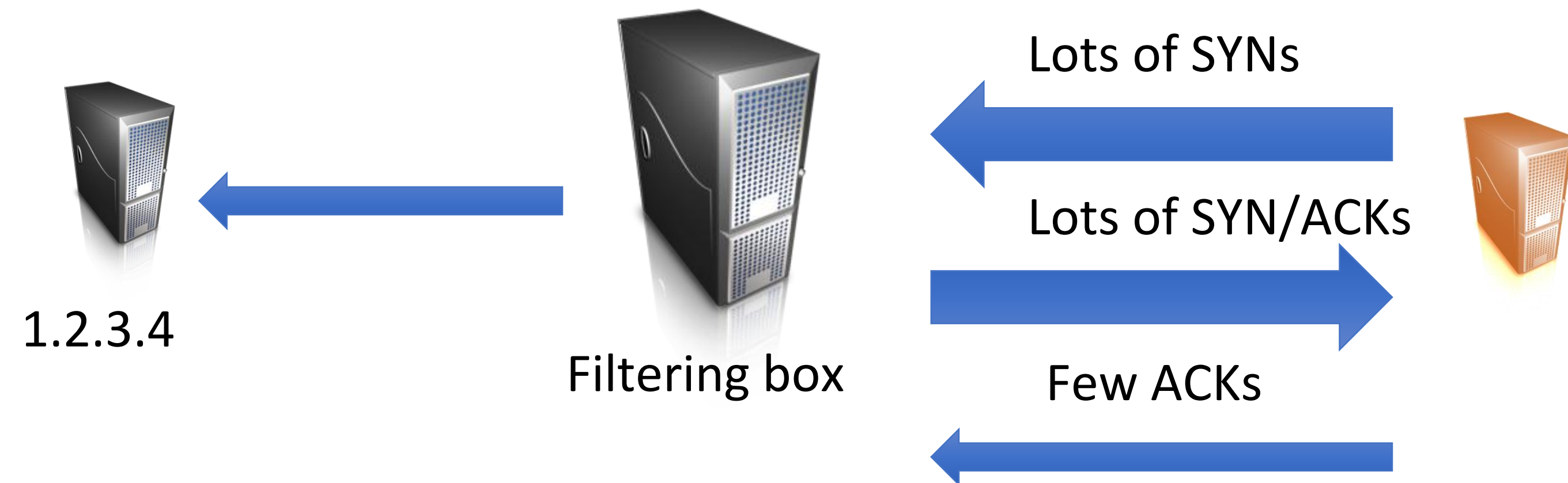
- **BCP 38 (RFC 2827)**
 - upstream ingress filtering to drop spoofed packets
 - source address validation

BCP38: Network Ingress filtering



Before forwarding on packets, check at ingress that source IP legitimate

Preventing DoS: beat the power



Just need a beefy box to help with filtering. There are several anti-DoS protection

- Prolexic (acquired by Akamai)
- Cloudflare
- Google Cloud Armor

PROLEXIC
Now part of 




CLOUDFLARE®

Mirai

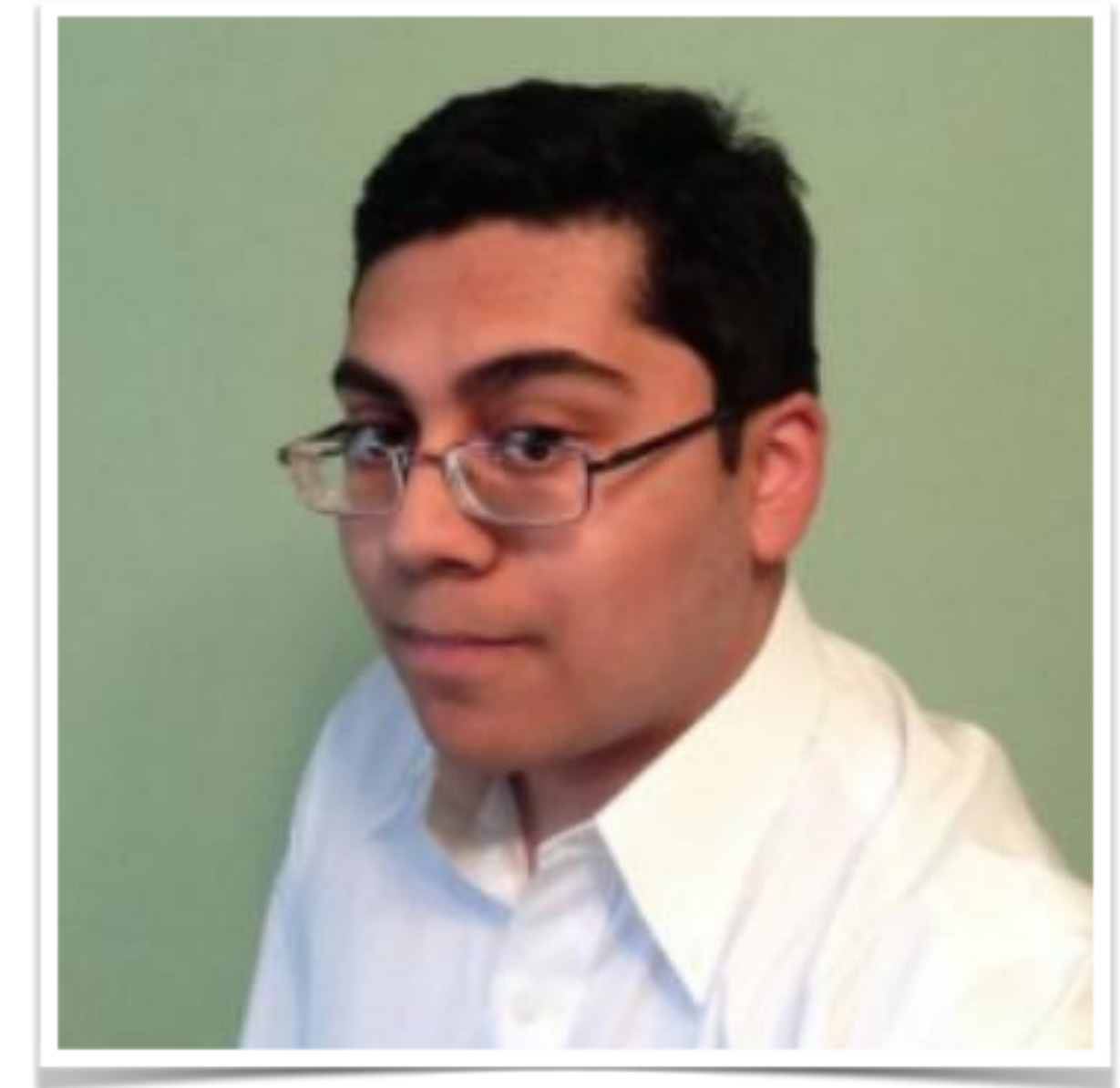
60 lines (60 sloc) | 778 Bytes

- September 2016, 600 Gbps attack on Krebs, Dyn.
- IoT devices: IP Cameras
- Peak infection: 600k devices, steady state: 200 to 300k
- Default username/passwords on IP Cameras

```
1  root xc3511
2  root vizxv
3  root admin
4  admin admin
5  root 888888
6  root xmhdipc
7  root default
8  root jauntech
9  root 123456
10 root 54321
11 support support
12 root (none)
13 admin password
14 root root
15 root 12345
```


Paras Jha, co-author of Mirai

- 2500 hours community service
- Home confinement
- 8.6 million USD in restitution
- Why DDoS?
 - Juvenile reasons (student at Rutgers CS)
 - Delay calculus exam
 - Prevent others from registering for an advanced CS course he wanted to take



<https://krebsonsecurity.com/2017/01/who-is-anna-senpai-the-mirai-worm-author/>

<https://krebsonsecurity.com/2018/10/mirai-co-author-gets-6-months-confinement-8-6m-in-fines-for-rutgers-attacks/>